AI Governance Decision Exercise

Completed standard exercise on AI summarisation of internal meeting notes

Recommended outcome: Approve with conditions. The use is bounded and assistive, but approval should not become operational until data handling, vendor assurance, human review and correction controls are evidenced.

Boundary. This document is a learning exercise and preliminary governance analysis. It is not legal advice, a compliance certification or final organisational approval.

1 Scenario summary

Evidence label	Information
User provided information	The organisation proposes an AI tool to summarise internal, non-confidential meeting notes.
User provided information	The summaries will not make decisions, rank people, recommend outcomes or trigger actions.
User provided information	Employees must review every summary before use.
User provided information	Personal, customer, financial and health information is prohibited.
Assumption	The proposal is at a pre-approval stage and the tool may be supplied by a third party.
Missing evidence	No vendor contract, security assessment, data-flow description, accuracy test, retention configuration or operating record has been supplied.

The decision is whether the organisation may permit this limited use and, if so, what evidence and safeguards must be in place before deployment.

2 Questions for the user

- Purpose and necessity: Is AI justified and suitable, and what simpler alternative exists?
- Affected people: Who benefits, may be misrepresented or may struggle to correct the record?
- Data: What information may enter despite the prohibition, and how will it be processed?
- Autonomy and oversight: When is employee review meaningful rather than a rubber stamp?
- Possible harms: What could follow from an inaccurate, incomplete or insecurely handled summary?
- Governance and regulatory exposure: What policies, standards, roles and legal questions apply?
- Third-party dependency: What must be established about the vendor and its supply chain?
- Reversibility: Can the organisation stop, delete, correct and return to a manual process?

- Initial decision: Approve, approve with conditions, restricted pilot, pause, redesign, escalate or reject?

User decision

Approve with conditions. The learner reasoned that evidence should justify and support the summary before it is relied upon.

3 Provisional risk assessment

Element	Assessment	Rationale
Inherent risk	Moderate	The system is assistive and does not trigger decisions, but inaccurate summaries can distort records, omit actions, misattribute statements and expose internal information.
Key drivers	Accuracy, privacy and operational reliance	Risk increases when absent employees or managers rely on a summary without access to the original discussion.
Control design	Promising but incomplete	Mandatory review, prohibited-data rules and bounded functionality are appropriate design elements, but important operational detail is absent.
Operating evidence	Not demonstrated	No review logs, test results, access records, data-loss-prevention evidence, vendor assurances or deletion confirmation were supplied.
Residual risk	Not yet concluded	Residual risk can be rated only after controls are implemented and their effectiveness is evidenced.
Uncertainty	Material but manageable	Vendor data use, hosting, retention, subprocessors, model changes, security testing and accidental submissions remain unknown.

Risk reasoning

The use is not inherently high impact because it does not determine access to opportunities, make decisions or control safety-critical activity. Nevertheless, the organisation should not label it low risk merely because the intended content is non-confidential. Meeting notes can still contain personal information, commercially sensitive context or statements that influence later actions.

4 Applicable governance considerations

- AI governance: define the approved purpose, prohibited uses, accountable owner, approval route, change-review trigger and retirement process.
- ISO/IEC 42001: consider operational planning and control, AI system impact assessment under Clause 8.4, documented responsibilities, monitoring and continual improvement.

- Information security: apply access control, secure configuration, logging, supplier assurance, incident handling and data-deletion requirements consistent with the organisation's ISMS and ISO/IEC 27001 where applicable.
- Privacy: determine whether personal data is likely to be processed despite the restriction; assess lawful basis, transparency, minimisation, retention, transfers and processor obligations where the GDPR applies.
- Records management: define whether the AI output is a draft, when it becomes an official record, how corrections are made and how long source notes and approved summaries are retained.
- Acceptable use: prohibit sensitive categories, unreviewed circulation, automated action-taking and use outside the approved meeting-note context.
- Accountability: assign a business owner as decision owner, supported by AI governance, information security, privacy, procurement and records-management functions.

5 Required controls

Priority	Control	Status and evidence needed
1	Approved-use boundary	Proposed. Document that the tool produces drafts only and may not decide, rank, recommend, trigger actions or process prohibited data.
2	Human review procedure	Proposed. Reviewer must access source notes, understand limitations, have sufficient time, correct or reject output and record approval.
3	Data minimisation and prevention	Proposed. Use approved templates, warnings, redaction guidance and appropriate technical controls to prevent or detect prohibited submissions.
4	Vendor and contract assurance	Missing. Confirm confidentiality, security, hosting, retention, subprocessors, training use, transfers, incident support, audit evidence and deletion.
5	Accuracy and robustness testing	Missing. Test representative meeting-note samples for omissions, distortions, attribution errors and unsupported action items before approval.
6	Access and logging	Missing. Restrict authorised users and retain proportionate records of submissions, reviews, corrections, incidents and approvals without creating excessive data.
7	Correction and incident process	Proposed. Enable withdrawal or correction of circulated summaries, notification of affected recipients and investigation of inappropriate data submission.
8	Change and exit	Proposed. Require notice of material model or service changes,

	management	reassessment triggers, export capability, access removal and verified deletion on offboarding.

Control status note. The scenario describes mandatory review and prohibited data categories, but these are treated as stated design requirements, not verified operating controls.

6 Evidence gaps

Missing evidence	Why it matters	Owner or next step
Data-flow and architecture description	Shows where notes, prompts, logs and outputs travel and persist.	Technology owner and vendor
Vendor terms and data-processing commitments	Establishes retention, training use, subprocessors, transfers, incidents and deletion.	Procurement, privacy and legal counsel where needed
Security assessment	Tests identity, access, encryption, logging, isolation and incident controls.	Information security
Accuracy test results	Demonstrates performance on representative notes and identifies failure patterns.	Business owner and AI assurance
Human-review procedure and records	Shows that reviewers can intervene and that review occurs in practice.	Process owner
Data-restriction enforcement evidence	Tests whether accidental personal or sensitive information is prevented, detected and handled.	Privacy and information security
Records and correction procedure	Defines official-record status, retention and correction of circulated errors.	Records-management owner

7 Escalation finding

Finding: Specialist review is advisable before operational approval, but mandatory high-impact escalation is not currently indicated.

The intended use is bounded, assistive and reversible and does not make or trigger consequential decisions. Review should nevertheless involve information security, privacy, procurement and records management because vendor processing and accidental personal-data entry remain materially uncertain. Legal counsel should be consulted if the privacy assessment identifies uncertain lawful-basis, transfer or contractual issues.

Decision owner: the accountable business or process owner, acting through the organisation's AI approval process. The vendor or an individual end user should not grant final approval.

8 Recommended decision

Approve with conditions for the defined meeting-note summarisation purpose only. No broader use, unreviewed circulation or automated action-taking is approved.

Conditions before operational use

- Complete vendor, privacy and information-security due diligence and document the approved data flow.
- Contractually prohibit unauthorised training use and define retention, subprocessors, transfers, incident notification and verified deletion.
- Test the tool on representative, appropriately prepared meeting notes and define acceptable accuracy and error-handling criteria.
- Implement a documented human-review procedure requiring comparison with source notes, correction authority and recorded approval.
- Implement enforceable data-minimisation measures and a response process for accidental submission of prohibited information.
- Define official-record status, correction, retention, change-review and offboarding processes.
- Begin with limited users and monitor errors, corrections, prohibited-data incidents and user reliance before broader rollout.

If the organisation cannot obtain acceptable vendor commitments or demonstrate effective review and data controls, approval should be withheld and the use redesigned or paused.

9 What the user assessed well

- Identified a legitimate efficiency purpose while recognising that a standard meeting-minutes template is a viable alternative.
- Kept the system within an assistive boundary and prohibited decision-making, ranking, recommendations and automatic action.
- Recognised that absent employees and managers may rely on distorted summaries and may struggle to detect errors.
- Noticed the tension between prohibiting personal information and the reality that meeting notes may naturally contain employee details.
- Connected inaccurate summaries to missed actions, damaged trust, unreliable records and reputational consequences.
- Identified acceptable-use, privacy, ISO/IEC 42001, accountable ownership, vendor due diligence and offboarding as governance needs.
- Selected a proportionate outcome rather than treating a bounded workplace tool as either risk-free or automatically unacceptable.

10 Learning points

Separate use-case risk from controls

The system’s bounded purpose reduces inherent exposure, while employee review and data restrictions are controls. They should not be used to describe inherent risk.

A stated control is not operating evidence

Mandatory review sounds appropriate, but effectiveness requires procedures, reviewer capability, time, source access, correction authority and review records.

Do not conclude residual risk too early

Residual risk remains unknown until the controls are implemented, tested and monitored.

Prohibitions need enforceability

A rule against personal data may be unrealistic for meeting notes unless supported by minimisation, redaction, technical prevention, training and incident handling.

Low-impact uses still need lifecycle governance

Vendor change, retention, correction, monitoring and offboarding matter even when the AI does not make decisions.

Overall coaching feedback

The learner's reasoning became progressively stronger as the exercise moved from business purpose to evidence and assurance. The main improvement is to state conditions in testable terms: identify the required evidence, the responsible owner and what happens when evidence is insufficient. That shift turns a sensible governance opinion into a defensible organisational decision.

This exercise does not provide legal advice, certify compliance or grant final organisational approval. Findings must be validated against the organisation's actual system, contracts, jurisdiction, policies and risk appetite.